

# OTA v1.0 Specification Security Audit

Open-then-Audit Protocol 攻撃経路監査・Critical/High 修正報告

Independent Specification Review

Final Re-audit – 2026-08-07

## 概要

本報告は、OTA v1.0 Whitepaper を、仕様不一致の校正ではなく、攻撃者が暗号を破らずに不正 claim を成立させる、slash を回避する、未成熟出力から価値を取得する、または低コストで node を停止させる具体的経路に基づいて監査した。初稿に対し Critical 5 件、High 9 件を特定し、Whitepaper 本文へ規範修正を反映した後に再監査した。

最終結果は、明示した host finality、future entropy、evidence inclusion-liveness、canonical VM assumptions の内側で、未解決 Critical 0 件、未解決 High 0 件である。ただし、これは仕様レベルの評価であり、Qwen3.6 reference ComputeSet の bit-exact runtime、A throughput overhead 15% 以下、8-core・12 GB node で 1 claim/s という性能は未実装・未測定である。したがって OTA-Work shadow profile は設計上条件付き GO、public value-bearing deployment は activation gates 完了まで NO-GO とする。

## 目次

|     |                                                                      |   |
|-----|----------------------------------------------------------------------|---|
| 1   | 監査範囲                                                                 | 3 |
| 2   | 重大度基準                                                                | 3 |
| 3   | 初回監査結果                                                               | 3 |
| 4   | Critical Findings and Fixes                                          | 4 |
| 4.1 | C-01: Audit draw selective opening and branch retry . . . . .        | 4 |
| 4.2 | C-02: Sparse junction is exported as trusted output . . . . .        | 4 |
| 4.3 | C-03: Checkpoint withholding prevents DefectProof . . . . .          | 5 |
| 4.4 | C-04: Shared collateral and premature reward escape . . . . .        | 5 |
| 4.5 | C-05: Host entropy anchor shopping . . . . .                         | 5 |
| 5   | High Findings and Fixes                                              | 6 |
| 5.1 | H-01: Interactive challenge can slash an honest offline A . . . . .  | 6 |
| 5.2 | H-02: Proof stealing and self-report rebate . . . . .                | 6 |
| 5.3 | H-03: Evidence settlement starvation . . . . .                       | 6 |
| 5.4 | H-04: Canonical VM bug becomes automatic mass confiscation . . . . . | 7 |
| 5.5 | H-05: 1 claim/s resource exhaustion . . . . .                        | 7 |
| 5.6 | H-06: Worker checkpoint path collapses token throughput . . . . .    | 7 |

---

|     |                                                                              |   |
|-----|------------------------------------------------------------------------------|---|
| 5.7 | H-07: Full node is silently required to serve the entire 35B model . . . . . | 7 |
| 5.8 | H-08: Evidence horizon shorter than full replay time . . . . .               | 7 |
| 5.9 | H-09: Model/weight substitution . . . . .                                    | 8 |
| 6   | Re-audit Result                                                              | 8 |
| 7   | Residual Medium Risks and Assumptions                                        | 8 |
| 8   | Required Implementation Audit                                                | 9 |
| 9   | Conclusion                                                                   | 9 |

## 1 監査範囲

対象は **OTA v1.0: Open-then-Audit Protocol** の日本語 Whitepaper Revision 1.0 である。監査範囲は次を含む。

- ExecutionCommit、OpenAnnounce、future audit entropy、18 interval sampling;
- checkpoint trace、Trace Availability Object、DefectProof;
- dedicated escrow、immature reward、maturity、freeze-and-settle;
- OTA-Work core profile と Output Consumption Rule;
- 1 claim/s、8 cores、12 GB、NVMe、Qwen3.6 reference ComputeSet;
- reorg、censorship、resource exhaustion、runtime nondeterminism。

実装コード、GPU kernel、model conversion toolchain、host consensus 実装、token economics の実測値は監査対象外である。

## 2 重大度基準

| Severity              | Definition                                                                                                                                        |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Critical              | 暗号を破らずに、false claim を受理・成熟させて protocol または外部 application から重大価値を取得する、valid fraud evidence が存在しても担保へ到達させない、または正直参加者を systematically slash する具体的経路。 |
| High                  | 攻撃成功率・利益・検閲能力を大幅に高める、resource budget を現実的コストで枯渇させる、wrong slash または liveness failure を広範に起こす具体的経路。                                                 |
| Medium                | 前提の弱さ、運用・測定不足、限定的 DoS、単一 host failure、または activation 前に検証すべき実装リスク。                                                                                |
| Specification blocker | Encoding や用語の矛盾。重要ではあるが、単独で具体的な不正利益経路を示さない限り Critical とは数えない。                                                                                     |

### 監査方針

単なる式・用語・未記入値の不一致は Specification blocker として分離する。各 Critical/High は、攻撃者の手順、得られる利益、既存規則が失敗する理由、修正後に経路が閉じる理由を示す。

## 3 初回監査結果

| Class                | Found | Fixed | Open after re-audit |
|----------------------|-------|-------|---------------------|
| Critical             | 5     | 5     | 0                   |
| High                 | 9     | 9     | 0                   |
| Medium / assumptions | 6     | —     | 6                   |

## 4 Critical Findings and Fixes

### 4.1 C-01: Audit draw selective opening and branch retry

**Attack path.**

1. A commits a trace containing many defective intervals.
2. If audit indices are known before A becomes economically committed, A opens only when the sample avoids defects.
3. Alternatively, A reopens the same claim after a short reorg and obtains a second entropy draw.
4. Repetition turns a low-probability escape into a near-certain successful claim.

**Impact.** 18-interval detection becomes cosmetic because A chooses whether the draw counts.

**Fix.** Whitepaper Sections 7–8 require: ExecutionCommit finality, one-shot OpenAnnounce, OpenAnnounce finality, then future HostEntropy. ClaimID and nullifier prevent multiple opens. Deep reorg after finality is explicitly a host failure. Host entropy cannot be selected by A, and an entropy bias budget is required.

**Closure.** A cannot observe or select the audit set before the irreversible open. Under the host finality assumption, no legal second draw exists. **Status: FIXED.**

### 4.2 C-02: Sparse junction is exported as trusted output

**Attack path.**

1. A performs almost all computation but changes one internal transition or output-related junction.
2. With  $q$  intervals, pre-acceptance probability of sampling the one junction is approximately  $16/(q-2)$ .
3. The 18 interval package passes.
4. An oracle, bridge, financial application, or external consumer treats PASS as final semantic correctness and acts before full replay.
5. Later slash cannot reverse the external effect.

**Impact.** A can purchase unbounded external value with a bounded escrow. This is not solved by increasing the burn percentage.

**Fix.** Whitepaper Section 12 makes the core OTA-Work output non-authoritative and non-consumable. Core claims have no host ordering weight, transaction effect, bridge/oracle authority, or final semantic attestation. An output-consuming application must perform canonical full replay, accept a separately specified replay-auditor assumption, or use another proof system before consumption.

**Closure.** Within OTA-Work scope, a sparse semantic change yields no external authority and no compute-saving benefit if full work was performed. Output profiles that violate the consumption rule are explicitly outside activation. **Status: FIXED in core profile.**

### 4.3 C-03: Checkpoint withholding prevents DefectProof

#### Attack path.

1. A commits only a TraceRoot and provides witnesses for the sampled 18 intervals.
2. A withholds the remaining ordered checkpoint digest vector.
3. A watcher full-replays and knows the output is false but cannot prove membership of A's claimed  $D_j, D_{j+1}$  or locate the first divergence against the committed vector.
4. No objective proof can be constructed; challenge window expires; reward matures.

**Impact.** Discovery and enforceability separate. The protocol promises fraud proofs that attackers can make unavailable.

**Fix.** Whitepaper Section 10 requires the complete ordered checkpoint digest vector in a Trace Availability Object before audit entropy begins. DA root, length, chunk root, erasure parameters, and retention horizon are committed. Claim acceptance fails closed if DA is unavailable. DefectProof does not need future cooperation from A.

**Closure.** A can withhold and forfeit, or publish and remain provable; it cannot both mature and deny the checkpoint vector through a legal state transition. **Status: FIXED.**

### 4.4 C-04: Shared collateral and premature reward escape

#### Attack path.

1. A opens many claims against one escrow or withdraws collateral after AuditPackage acceptance.
2. Multiple fraud proofs arrive later.
3. First settlement consumes the collateral; remaining claims have valid evidence but no reachable asset.
4. Alternatively, reward becomes spendable before the evidence horizon and cannot be clawed back without state reversal.

**Impact.** “Automatic slash” exists in prose but not economically; later victims receive an empty promise, humanity's favorite financial instrument.

**Fix.** Whitepaper Sections 13–14 require a dedicated per-open-claim escrow, aggregate maximum-liability invariant, evidence-horizon lock, immature reward, evidence-before-maturity ordering, and atomic FrozenForSlash transition. Escrow lower bound uses irrecoverable burn and measured detection probability.

**Closure.** Each claim's maximum liability is reserved before open, cannot be reassigned, and is frozen before owner spend. Reward has no downstream spend until maturity. **Status: FIXED.**

### 4.5 C-05: Host entropy anchor shopping

#### Attack path.

1. A colludes with a host block producer or finality participant.
2. Multiple candidate entropy anchors/windows are privately evaluated.
3. The branch whose 16 sampled intervals avoid the defective set is published.
4. The attack converts one committed trace into repeated audit draws.

**Impact.** Sampling security is reduced by the number of affordable draws; large escrow increases the value of grinding.

**Fix.** Whitepaper Sections 3 and 7 pin a single entropy interface, fixed anchor, finality-before-entropy order, and prohibit A-selected source/anchor. Host activation requires a published bias budget with expected maximum bias benefit below expected minimum withholding/reorg cost. Un-measured entropy sources are shadow-only.

**Closure.** No legal protocol freedom remains for anchor shopping. A host majority able to violate its finality/bias claim remains an explicit host consensus failure, not an OTA safety claim. **Status: FIXED within stated host assumption.**

## 5 High Findings and Fixes

### 5.1 H-01: Interactive challenge can slash an honest offline A

**Attack path.** Challenger submits many challenges; host producers censor A's responses; A times out and loses escrow despite correct execution.

**Fix.** Interactive response, turn clock, and post-acceptance A obligation were removed. DefectProof is self-contained and invalid proof changes no state. **Status: FIXED.**

### 5.2 H-02: Proof stealing and self-report rebate

**Attack path.** A reporter broadcasts a proof; producer copies it, changes payout key, and front-runs. A may also self-report through another key and recover a large fraction of slash.

**Fix.** DefectCommit binds EvidenceID, proof hash, reporter key, and salt; it grants bounty priority only. Reporter and compensation are each capped at 10%; burn is at least 80%, 90% recommended for false execution. **Status: FIXED.**

### 5.3 H-03: Evidence settlement starvation

**Attack path.** Host accepts evidence but schedules zero settlement work, allowing owner spend or indefinite freeze without burn.

**Fix.** Valid evidence atomically freezes before proof settlement and owner spend; host adapter provides reserved evidence byte/cycle band. EvidenceID is idempotent and maturity processes after evidence. **Status: FIXED.**

## 5.4 H-04: Canonical VM bug becomes automatic mass confiscation

**Attack path.** Two runtimes disagree on rounding/router/order; honest A is classified as fraudulent; automatic slash burns collateral without appeal.

**Fix.** ComputeSet pins integer width, quantization, rounding, overflow, router tie-break, tokenizer, operation order, disabled features, golden vectors. Activation requires two independent implementations, shadow mode, and a 10/25/50/100% slash ramp with zero wrong-slash tolerance. **Status: FIXED at specification/activation level.**

## 5.5 H-05: 1 claim/s resource exhaustion

**Attack path.** Each object respects a local cap, but 18 witnesses, weight tiles, checkpoint vector, proofs, and claims/s multiply into unbounded CPU, I/O, network, and storage.

**Fix.** Whitepaper Sections 15–17 cap object, claim, and time-window bytes/cycles; require product-aware activation reports; set reference aggregate CPU at 0.9 core-second/claim and total OTA CPU below 30% of system capacity. **Status: FIXED as a fail-closed deployment gate.**

## 5.6 H-06: Worker checkpoint path collapses token throughput

**Attack path.** Every checkpoint synchronizes GPU, copies full KV/state to CPU, hashes synchronously, and stalls forward execution. A throughput falls far below economic viability.

**Fix.** Whitepaper Section 6 prohibits per-checkpoint global sync, full-state rehash, synchronous large copies, duplicate expert/weight execution, and second full inference. Activation requires  $Throughput_{OTA}/Throughput_{base} \geq 0.85$ . **Status: FIXED as a measurable gate.**

## 5.7 H-07: Full node is silently required to serve the entire 35B model

**Attack path.** Specification claims 8-core/12 GB decentralization while verifier actually loads all 35B weights into RAM/VRAM or performs complete token generation, excluding ordinary nodes.

**Fix.** Whitepaper Section 16 separates Worker and node capability. Node stores the hash-pinned package on NVMe, loads only referenced weight tiles, executes selected intervals, and needs no GPU/full serving capability. The hardware claim remains inactive until benchmarks pass. **Status: FIXED specification ambiguity; performance remains a gate.**

## 5.8 H-08: Evidence horizon shorter than full replay time

**Attack path.** Qwen full replay and proof construction take longer than the challenge window, so fraud is known but becomes time-barred before inclusion.

**Fix.** Challenge horizon must exceed p99 full replay, p99 proof construction, inclusion, stable depth, and margin. A finalized evidence commitment can extend the proof window under precommitted rules. **Status: FIXED.**

## 5.9 H-09: Model/weight substitution

**Attack path.** A runs a smaller or modified model, fabricates metadata identifying it as the approved model, and supplies locally consistent sampled witnesses.

**Fix.** ComputeSetID pins ModelRoot, tokenizer, quantization, VM, shape, checkpoint rules, and golden vectors. Every selected weight tile has a Merkle path to ModelRoot. External vendor API output is not a validity input. **Status: FIXED.**

## 6 Re-audit Result

### Final specification-level verdict

Under the stated host finality, future entropy, data availability, evidence inclusion-liveness, collision resistance, and canonical VM assumptions:

- unresolved Critical: **0**;
- unresolved High: **0**;
- OTA-Work shadow profile: **conditional GO**;
- public value-bearing profile: **NO-GO until every activation gate passes**;
- output-consuming profile: **NO-GO unless Output Consumption Rule is implemented.**

Critical/High が 0 という結果は、18 区間が full execution proof になったという意味ではない。Core が semantic output を権威化せず、外部価値を scope 外へ追い出したこと、proof data を available にしたこと、liability を専用 escrow へ先に固定したことによる。

## 7 Residual Medium Risks and Assumptions

1. **Host majority censorship.** Evidence commitment を含めて期限まで完全 censor できる host majority には slash を保証しない。
2. **Deep reorg.** Open finality を破る deep reorg では複数 draw や state rollback が起こり得る。
3. **No honest output replayer.** Output-consuming application が full replay を行わず、選んだ auditor も collude する場合、semantic defect は残り得る。
4. **Unmeasured performance.** A overhead 15% 以下、node 50 ms/interval、12 GB RAM、NVMe I/O は実測前である。
5. **Model supply chain.** Canonical weight conversion、signing key、release manifest の侵害は ComputeSet admission risk である。
6. **Non-economic attacker.** 自身の escrow loss を無視する攻撃者は bounded bandwidth/storage cost を host へ課せる。Rate and byte caps で上限化する。



## 8 Required Implementation Audit

Specification 監査後に、少なくとも次を実装で検証する必要がある。

- canonical integer kernel と GPU optimized kernel の bit-exact cross-platform vectors;
- Qwen MoE router、8 routed + shared expert の order/tie-break;
- checkpoint digest、trace spool、Merkle builder の throughput benchmark;
- 18 interval witness の CPU、wall time、RSS、NVMe read、network bytes;
- TAO chunk loss、withholding、pruning、restart、clean sync;
- one-shot OpenAnnounce、finality、reorg、entropy draw;
- invalid/valid/duplicate DefectProof、proof theft、self-report;
- escrow overcommit、withdraw race、maturity/evidence same-unit ordering;
- slash ramp、pause、upgrade、old ComputeSet semantics preservation;
- 1 claim/s long-run queue stability と adversarial burst。

## 9 Conclusion

OTA v1.0 の最終仕様は、少数区間 sampling を万能証明として扱わず、何を事前に検出し、何を事後反証し、何を core scope から外すかを分離した。最重要修正は、Open 後 entropy、全 checkpoint vector DA、non-interactive proof、dedicated escrow、immature reward、non-authoritative core output である。

この構造により、初稿で成立した Critical/High 攻撃経路は仕様上閉じられた。ただし実装が同じ性質を持つかは別問題である。Qwen3.6 reference profile と 8-core・12 GB・1 claim/s は、PDF へ書いた瞬間に現実になる便利な呪文ではない。Activation gate の測定値が Whitepaper の数値を満たした場合にのみ、その profile を公開可能と判定する。